

EU Cyber Resilience Act 101

and why you, programmer, care

i am not a lawyer, i've just read the CRA a whole bunch of times



AKI ROSE BRAUN

Former software engineer; rapporteur for
CRA vertical standards @ ETSI, contributor to
CRA horizontal standards @ CEN-CENELEC

- bsky: @akiro.se
- masto: aki@toot.cat
- GitHub: gesa
- Ravelry: akibee
- Matrix: @akirose:matrix.org
- email: a@expertzebra.com



What is the CRA

and why am I talking about it

Rapporteur

- Interprets the regulation from a *technical* perspective
- Not a judge, not a lawyer
- Acts as editor for standards that help implement the regulation

Why is the CRA

and why do you care



Co-funded by
the European Union

**it probably
impacts you
(no matter where
you are based)**



Some quick assumptions

(for my insights to be helpful)

- I'm speaking about the broad requirements that apply to **all products**
 - Browsers are special in the CRA. Everything I'm talking about applies, but Dan will get into the extra obligations
- Your product contains *something* delivered to your user, like **a hardware device** or **software they install** on their own devices
 - Pure SaaS is regulated elsewhere and outside my scope
 - Websites—even PWAs—are not in scope of the CRA
- Your product is a **product**, which involves “economic activity”

**n.b. Open Source details at tomorrow
morning's breakout session**

Product, not process

What do you have to do

the short version

- Risk assessment
- Industry security best practices
- Responsible vulnerability handling
- Documentation of all of the above

Understand the risk assessment

“Essential Cybersecurity Requirements”

(from here on out I’ll call them ESRs. The “S” is for “security”.)

products with digital elements shall:

- (a) be made available on the market **without known exploitable vulnerabilities**;
- (b) be made available on the market with a **secure by default configuration**, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the possibility to reset the product to its original state;
- (c) ensure that vulnerabilities can be addressed through security updates, including, where applicable, through **automatic security updates** that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them;
- (d) ensure protection from unauthorised access by appropriate **control mechanisms**, including but not limited to authentication, identity or access management systems, and report on possible unauthorised access;
- (e) **protect the confidentiality of stored, transmitted or otherwise processed data**, personal or other, such as by encrypting relevant data at rest or in transit by state of the art mechanisms, and by using other technical means;
- (f) **protect the integrity of stored, transmitted or otherwise processed data**, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions;
- (g) process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (**data minimisation**);
- (h) protect the **availability of essential and basic functions**, also after an incident, including through resilience and mitigation measures against denial-of-service attacks;
- (i) **minimise the negative impact** by the products themselves or connected devices on the availability of services provided by **other devices or networks**;
- (j) be designed, developed and produced to **limit attack surfaces**, including external interfaces;
- (k) be designed, developed and produced to **reduce the impact of an incident** using appropriate exploitation mitigation mechanisms and techniques;
- (l) provide security related information by **recording and monitoring relevant internal activity**, including the access to or modification of data, services or functions, with an opt-out mechanism for the user;
- (m) provide the possibility for users to **securely and easily remove on a permanent basis all data and settings** and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner.

**No more earmuffs approach.
The whole product must be secure.**

INSERT VULNERABILITY HANDLING SLIDE HERE

idk man, it's a whole other talk.

Vulnerability handling overview

- "early warning"
- "vulnerability notification"
- "final report"
- tell your users or ENISA will.
- upstream your fixes

on to the documentation



Co-funded by
the European Union

“Show, don’t tell”

(okay, actually sorta tell)

ADR: architecture decision record



- intended purpose
- versions covered
- photos & illustrations
- user instructions
- architecture description
- component relationship diagram
- SBOM (Software Bill of Materials)



document your good choices



- vulnerability handling process
- responsible disclosure policy
- security update strategy
- risk assessment
- test results
- all other standards

This is so much! How to do it all?



This is so much! How to do it?



“Don’t try to boil the ocean”

—standards people, like all the time

Apply vertical pressure

Apply vertical pressure

1. Get an executive on board
2. Plan for long-term documentation
3. Assemble inventories
 - third-party components
 - architecture documentation
 - vulnerability handling policies
4. Carve off a logical piece of your product to pilot automation
5. Document internally how to get your component CRA-ready
6. Ship org-wide

Go forth and terrify an executive.

Now, the finer details for browsers

Web browser CRA standard: A work in progress

Daniel Ari Ehrenberg Goldberg
Former ETSI rapporteur, EN 304 617
Web Engines Hackfest
A Coruña, 2026-06-15



Agenda

- What is a web browser
 - What do browsers already do well
 - Untreated risks in web browsers on the market
 - How might the CRA apply to web browsers
-
- Mature draft and feedback on it
 - Next steps plan
 - The shared skeleton from ETSI
 - Current progress

Who am I?

“Daniel Ehrenberg”, a.k.a. @littledan

10+ years in web standards, mostly JavaScript, (dabbling in HTML, WebAssembly)

Former president of Ecma International

Previously worked at Google, **Igalia**, Bloomberg

Live in Les Roquetes del Garraf

(Sant Pere de Ribes, Catalunya)

Former co-rapporteur of the group in ETSI standardizing web browser cybersecurity requirements

I don't represent ETSI, not currently a member



What is a web browser?

Commission Implementing Regulation (EU) 2025/2392 of 28 November 2025 on the technical description of the categories of important and critical products with digital elements pursuant to Regulation (EU) 2024/2847 of the European Parliament and of the Council

C/2025/8052

Software products with digital elements that enable end users to access, render, and interact with web content and services hosted on servers that are connected to networks such as the Internet. They typically include a browser engine for interpreting and displaying content written in markup language (e.g. HTML), support for web protocols (e.g. HTTP, HTTPS), the ability to execute scripts and manage user inputs as well as storage of temporary or persistent data from websites (cookies).

This category includes but is not limited to standalone applications that fulfil the functions of browsers, embedded browsers intended for integration into another system or application as well as browsers with AI agent integration.

What is a web browser?

- Software which accesses general web content, not just first-party content
- Being built with web technologies does not make something a browser

Your Electron app is probably not a web browser

But a WebView component which can access arbitrary websites is

...if that component is the product itself

Websites including PWAs are out of scope of the CRA

Mobile apps built with web technologies including WebAPKs are products in scope, but they are probably not web browsers (so, “default products”)

Browsers are Important™

→ need to conform to a harmonized standard or get a third-party assessment to be put on the EU market

Reasonable, because:

- Trusted base for lots of other software
- If browsers are insecure, everything else you're doing is insecure

What do browsers do well?

All major browsers are open source at their core and use strong security practices, including:

- Frequent updates addressing security issues
- Prompt handling of any discovered or reported vulnerability
- State-of-the-art encryption implementations, used in TLS
- UIs which demonstrate risk, trust context, block some risky actions
- Design of APIs which protect privacy, preserve privilege boundaries
- Sandboxing/multiprocess architecture
- Fuzz testing, conformance testing
- Much, much more...

Untreated risks in browsers on the market

Many web browsers are based on open source upstream browsers, and then not updated over time.

There is a constant stream of CVEs against all web browsers.

If you let users access the web, they will often trust their browser, and do arbitrarily important things in the web browser.

There is no low-risk use case for a web browser

You need to update against upstream regularly (at least monthly)

How the CRA might apply to web browsers

Annex 1 part 1 (1) (e)

“protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by state of the art mechanisms, and by using other technical means;”

- TLS
- How to define that?
 - Standards versioning vs EU goals

How the CRA might apply to web browsers

Annex 1 part 1 (1) (g)

“process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimisation);”

- Same-Origin Policy
- Only give personally identifying information with user consent
- **Third-party cookies?**
 - Web browsers work towards data minimization of apps inside of them

How the CRA might apply to web browsers

Annex 1 part 1 (1) (k)

“be designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques;”

- Sandboxing
- Multiprocess architecture
- But how do we make sure to be open to future innovations?

How the CRA might apply to web browsers

Annex 1 part 1 (1) (m)

“provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner.”

- Product-wide reset button
- **Clearing storage per-site?**
 - Web browsers are basis for other CRA-compliant software

Development of the standard

The “Mature Draft”

From December 23, 2025

433 pages

Detailed requirements and assessments

Capability/conditions framework

Draft ETSI EN 304 617 V0.1.0 (2025-12)



Cyber Security (CYBER);

CRA;

Cybersecurity requirements for Browsers

Exercising one of the Principles of international standardization - Openness - and taking it to a different level, ETSI is piloting informal public consultations of the vertical standards in support of the Cyber Resilience Act at a much earlier stage than it is usual in the standardization world. In this context, please keep in mind that the standard draft herein is an INTERIM DRAFT, which expectably will be subject to substantial changes before its target publication date in the second semester of 2026.

Disclaimer

This **INTERIM DRAFT** document is provided for information and is for future development work within the ETSI Technical Committee CYBER EUSR Working Group (CYBER-EUSR) only. ETSI and its Members accept no liability for any further use/implementation of this Specification. Approved and published specifications and reports shall be obtained exclusively via the ETSI Documentation Service at <http://www.etsi.org/standards-search>

Commenting guidelines

Your comments to improve this early draft are very welcomed. To ensure the effectiveness of your contribution, please make sure to include the following elements in your comment:

1. Clear identification of the section of the draft your comment is referring to.
2. Objective proposal to delete content, add content or substitute content.
3. Concrete contribution (exact content you suggest including in the draft as an addition to, or in substitution of, existing content).

Feedback on the mature draft

Several parties posted detailed reviews

- **HAS assessment**
- Marshall Vale and Andrew Whalley, Google
- Sebastian Ledru et. al., Mozilla
- Giovanni Corti of Fondazione Bruno Kessler, Simone Onofri of W3C
- Bruce Lawson and Yngve, Vivaldi

All pointed to the need for a new approach

Next steps plan

- Common web security model, rather than defining multiple profiles
- Requirements to be more high-level, product-driven, from risk assessment
- Draft collaboratively among several contributors, with code review
- Follow the common cross-vertical structure by starting from the shared skeleton

The shared skeleton

- Emphasizes the top-down, product-driven approach:
- Requirements come from CRA paragraphs, rather than functional components

5. Technical requirements for the Products

This is the normative clause of the standard, defining the technical requirements to implement the Essential Security Requirements of the CRA regulation. The text of the regulation shall never be copied or interpreted in the standard.

The requirements shall be indexed, to facilitate their referencing, preferably using a common indexing structure throughout all standards.

Proposed structure for indexing the requirements:

REQ – PP – ESR – NNN

REQ: Used to identify requirement in the text

PP : Product short name added only if relevant when the product category may be divided in sub categories

ESR :Proposed abbreviations referring to the different essential requirements of the regulation

■ *NNN – Incremental and unique number*

ETSI

{Draft Skeleton} ETSI EN 304 6DD V0.0.21 (2026-02)

14

[Part of element] or [Release #]

It is strongly recommended to follow the sequence of the CRA Annex I requirements when defining the subclauses in Clause 5. However, where this structure would result in unnecessary duplication/overlap, subclauses and requirements may be organized in a more suitable way, provided that clear traceability to the relevant CRA Annex I requirements is maintained.

5.1 Introduction – Applicability of the requirements

If there is a matrix mapping the use cases to the technical requirements of the standard, it should be inserted in this clause. Alternatively, there can be such a matrix/mapping in each subclause below.

5.2 No known exploitable vulnerabilities

Proposed ESR code: KEV

This clause addresses the requirements in the CRA [i.1] Annex 1 Part 1 (2) (a).

5.3 Secure by design

Proposed ESR code SBD

This clause addresses the requirements in the CRA [i.1] Annex 1 Part 1 (2) (b).

5.4 Secure Updates

Proposed ESR code: SU

This clause addresses the requirements in the CRA [i.1] Annex 1 Part 1 (2) (c).

■ 5.5 Authentication and access control

Proposed ESR code: AC

Current progress in the new draft

Use cases (clause 4):

- Consumer standalone web browsers
 - "Enterprise" web browsers with enterprise policy controls
 - which may be used in critical infrastructure contexts
 - Embedded browser-like tabs with no access from the embedding application into the web content.
-
- Annex O: things not handled by this specification
 - Browsers with AI agent integration: too new and powerful for us to define risks and mitigations
 - WebViews deeply integrated with host app: significant risks if used with 3rd party content

Current progress in the new draft

- Annex V: Advice for derivative browsers, downstream of open source
 - **Rebase from upstream frequently**
 - Otherwise you are certainly shipping known exploitable vulnerabilities

Open Requirements for TLS

tls-reqs

into main_publish

Overview8

Commits2

Pipelines1

Changes1

6 open threads

^

v

⋮

Add a to-do item



Andrew Whalley @whalleya started a thread on the diff 3 hours ago

✓ Collapse replies

EN_CRA_Vertical_Harmonised_Standard_Skeleton_draft.md

371	384	
372	385	This clause addresses the requirements in the CRA <code>[i.1\]](#_ref_i.1)</code> Annex 1 Part 1 (2) (b).
373	386	
	387	+ [REQ-TLS-SBD-1] : The web browser shall be configured by default to reject TLS protocol versions, cipers and configurations which present high-risk known exploitable vulnerabilities.
	388	+
	389	+ Editor's note: Consider whether "high-risk known exploitable vulnerabilities" is an appropriate phrase, and whether this requirement should say "reject or warn" instead. See also REQ-TLS-CON-3.



Andrew Whalley @whalleya 3 hours ago

✓ 😊 ⋮

"at high (imminent?) risk of exploitation" perhaps? Back in the SHA1 deprecation days we'd want folks to move off known-weak algorithms before there were known practical exploits.

I do like the "configured by default" wording, since a deprecation story usually involves having an enterprise policy to allow use of weak configurations where somebody's taken a positive risk decision for their deployment

0 Assignees Edit

None - assign yourself

0 Reviewers Edit

None - assign yourself

Labels Edit

None

Milestone Edit

None

Time tracking ⌚ +

No estimate or time spent

3 Participants



Getting involved

We need your help to move this standard forward!

- #cra-browser:matrix.org
- Review and leave comments in <https://labs.etsi.org/rep/stan4cra/en-304-617>
- Join ETSI's CYBER EUSR committee
 - Internally, we develop via GitLab – make a PR against the markdown
 - If you're an open-source developer, you may be able to participate via OSI
- Contact Daniel Thompson if you're interested in participating
denjell@crabnebula.dev

labs.etsi.org/rep/stan4cra/en-304-617/-/issues

Sign in

ETSI Labs

Explore

Search or go to...

Project

EN 304 617 Browser

Manage

Plan

Issues

Issue boards

Milestones

Iterations

Wiki

Requirements

Code

Deploy

Operate

Monitor

Analyze

Help

STAN4CRA / EN 304 617 Browser / Issues

Open 10

Closed 0

All 10

New issue

Created date

Search or filter results...

Q

Comments on EN_CRA_Vertical_Harmonised_Standard_Skeleton_draft.md (Mar 17, 2026)

#10 · created 1 day ago by Chi-Hua Chen

To do

Proposal for Foundational Structural Re-Alignment of EN 304-617 in the Context of the Web Security Model and CRA

#9 · created 3 weeks ago by simoneonofri

1 To do

Reference to OCSP is outdated (ENC-REQ-7)

#8 · created 1 month ago by littledan

1 To do

Vivaldi browser feedback on draft spec

#7 · created 1 month ago by bruce-vivaldi

1 To do

Do claims matter?

#6 · created 1 month ago by bkardell

1 To do

updated 1 month ago

WebView definition not covering all types of WebViews

#5 · created 1 month ago by niklasmerz

1 To do

updated 3 weeks ago

Process architecture too prescriptive

#4 · created 1 month ago by Frederik Braun

1 To do

updated 1 month ago

Internet browsers or Web browsers?

3 To do

Q/A

Contact me:

dan@littledan.dev

